機密等級：■一般□限閱□密□機密

全一電子股份有限公司
JEBSEE ELECTRONICS CO.，LTD

資訊安全政策手冊

Information Security Management System Implementation Policy

文件編號：IS-V1-01

Doc.No.：IS-V1-01

制訂部門：情資安全部　審　核：吳仲銘　制　作：郭銘儒

文件版次：3.0　修訂日期：2025/05/09　制訂日期：2024/6/17

相關部門勾選	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V
部門名稱	營運管理處	業務部/市場行銷部	專案管理部	產品設計一部	產品設計二部	技術部	資料課	數位整合部	智慧賦能部	情資安全部	永續發展部	財務部	職安部	管理部	人資部	製造部	SMT	成型部	生產管理部	資材部	進出口課	工程部	品質保證部

表格編號：SP1-Q2-01-01 Rev1.1

	全一電子股份有限公司 JEBSEE ELECTRONICS CO.,LTD	文件編號	IS-V1-01
文件類別	文 件 變 更 紀 錄 表	制訂部門	情資安全部
文件名稱	資訊安全政策手冊 Information Security Management System Implementation Policy	文件版次	3.0

版次	變更摘要	修訂日期
1.0	資訊安全執行組初版發行，由召集人核准	6/17 ’24
2.0	增修：2.3、5.3.5，調整附件：ISO27001 資訊安全管理標準要求與內部適用文件稽核對照表	10/15 ’24
3.0	增修適用範圍、驗證範圍、資訊安全政策宣導新增目標及資訊安全流程與活動之權責單位	05/09 ’25

目錄

目錄 1
1.0 目的： 2
2.0 適用範圍： 2
2.1 資訊安全管理系統： 2
2.2 驗證地址： 2
2.3 驗證範圍： 2
3.0 用語及定義： 2
3.1 參考本公司資訊安全管理系統一至四階文件。 2
4.0 組織全景： 3
4.1 瞭解組織及其全景 3
4.2 瞭解關注方之需要及期望 3
4.3 決定資訊安全管理系統之範圍 3
4.4 資訊安全管理系統 3
5.0 領導作為： 3
5.1 領導及承諾 3
5.2 政策： 3
5.3 組織角色、責任及權限： 5
6.0 規劃： 7
6.1 因應風險及機會之行動 7
6.2 資訊安全目標與期達成之規劃 7
6.3 變更之規劃 7
7.0 支援： 7
7.1 資源 7
7.2 能力 7
7.3 認知 8
7.4 溝通或傳達 8
7.5 文件化資訊 8
8.0 運作： 8
8.1 運作之規劃及控制 8
8.2 資訊安全風險評鑑 8
8.3 資訊安全風險處理 9
9.0 績效評估： 9
9.1 監督、量測、分析及評估 9
9.2 內部稽核 9
9.3 管理審查 9
10.0 改善： 10
10.1 持續改善 10
10.2 不符合事項及矯正措施 10
附件：ISO27001 資訊安全管理標準要求與內部適用文件稽核對照表 11
附件：TISAX ISA 6.0.3 Statement of Applicability 與內部適用文件稽核對照表 13

1.0 目的：

全一電子股份有限公司(以下簡稱本公司)為強化資訊安全管理，確保所屬之資訊資產的機密性、完整性及可用性，以提供本公司之資訊業務持續運作之資訊環境，並符合相關法規之要求，使其免於遭受內、外部的蓄意或意外之威脅，特定此政策規範。

2.0 適用範圍：

2.1 資訊安全管理系統：

2.1.1 本公司依據 IS0 27001:2022 與 ISO27002:2022 及 TISAX VDA ISA 制定本手冊。

2.2 驗證地址：

2.2.1 XL Site：No.24-3, Xinle Rd., South Dist., Tainan City 702028, Taiwan (R.O.C.) (新樂廠，702 台南市南區新樂路 24-3 號(安平產業園區))

2.2.2 XR Site：No.18, Xinren Rd., South Dist., Tainan City 702015, Taiwan (R.O.C) (新仁廠，702 台南市南區新仁路 18 號(安平產業園區))

2.3 驗證範圍：

2.3.1 XL Site：Provision of the related information security activity for network service, computer room management, and Enterprise Resource Planning (ERP) and Manufacturing Execution System (MES) development, maintenance and management by Digital Intelligent Center. 數智驅動轉型處所提供網路服務、機房管理以及企業資源規劃（ERP）和製造執行系統（MES）開發、維護和管理之相關資訊安全管理活動。

2.3.2 XR Site：Network service, computer room management, and Manufacturing Execution System (MES) maintenance and management. 網路服務、機房管理以及製造執行系統（MES）維護和管理。

2.3.3 TISAX XL Site：The Scope comprises all processes and involved resources at the sites defined below that are subject to security requirements from partners in the automotive industry. Involved processes and resources include collection of information, storage of information and processing of information. 本範圍涵蓋下列定義廠區中，所有涉及的流程與資源，這些流程與資源須遵循汽車產業合作夥伴所要求的資訊安全規範。所涉流程與資源包括資訊的蒐集、儲存與處理。

2.3.4 TISAX XR Site：The Scope comprises all processes and involved resources at the sites defined below that are subject to security requirements from partners in the automotive industry. Involved processes and resources include collection of information, storage of information and processing of information. 本範圍涵蓋下列定義廠區中，所有涉及的流程與資源，這些流程與資源須遵循汽車產業合作夥伴所要求的資訊安全規範。所涉流程與資源包括資訊的蒐集、儲存與處理。

3.0 用語及定義：

3.1 參考本公司資訊安全管理系統一至四階文件。

4.0 組織全景：

4.1 瞭解組織及其全景

4.1.1 針對本公司進行組織全景分析，了解內、外部議題、關注者(Interested Party)對於資訊安全的要求與期望以及組織所執行的活動，與由其他組織執行活動間的界面與相依性，以協助本公司建立資訊安全管理系統，包括下列目的：

4.1.1.1 擬定運作範圍

4.1.1.2 擬定政策及目標

4.1.1.3 風險管理

依「資訊安全組織程序」IS-V2-01 與「組織全景分析程序」IS-V2-02 實施。

4.1.2 本公司應確定氣候變遷是否為相關議題，納入氣候變遷於資訊安全的相關的要求。

4.2 瞭解關注方之需要及期望

4.2.1 應透過訪談與主動資料蒐集方式，蒐集關注者對本公司資訊安全之需求與期望，依據系統進行分類，並填寫於「全景分析作業表」IS-V2-02-01 中。

註：利害相關者可能對氣候變遷有所要求。

4.3 決定資訊安全管理系統之範圍

4.3.1 資訊安全執行組應依據內、外部議題分析結果、關注者需求與期望、活動間的介面及相依性分析結果，分析評估本公司現有 ISMS 範圍是否須調整，記錄於「全景分析作業表」IS-V2-02-01，並取得資訊安全組織召集人之核准，作為本年度 ISMS 範圍的異動依據。

4.4 資訊安全管理系統

4.4.1 次年度資訊安全範圍之異動依據宜考量前年度執行情形於管審會議討論，並取得資訊安全組織召集人之核准。

5.0 領導作為：

5.1 領導及承諾

5.1.1 資訊安全管理委員會（以下簡稱資訊安全委員會）主任委員：

5.1.1.1 由本公司總經理擔任主任委員，並任命資訊安全委員會召集人

5.1.2 資訊安全委員會召集人（以下簡稱召集人）：

5.1.2.1 確保資訊安全政策與目標建立，且切合本公司策略方向；

5.1.2.2 確保整合 ISMS 要求於本公司流程中；

5.1.2.3 確保 ISMS 所需資源得以取用；

5.1.2.4 溝通有效的 ISMS 與遵循 ISMS 要求的重要性；

5.1.2.5 確保 ISMS 達成預定成效；

5.1.2.6 指揮與支援人員貢獻於 ISMS 有效性；

5.1.2.7 推動持續改善；

5.1.2.8 支援其他管理角色來展現用於負責領域的領導性。

5.2 政策：

5.2.1 願景與目標

5.2.1.1 資訊安全政策願景：

a. 強化人員知能
b. 避免資料外洩
c. 落實日常維運
d. 確保服務可用

5.2.1.2 依據資訊安全政策願景，擬定資訊安全目標如下：
a. 辦理資訊安全教育訓練，推廣人員資訊安全之意識與強化其對相關責任之認知。
b. 保護本公司業務活動資訊，避免未經授權的存取與修改，確保其正確完整。
c. 定期進行內部與外部稽核，確保相關作業皆能確實落實。
d. 確保本公司關鍵業務系統維持一定水準的系統可用性。

5.2.1.3 應針對上述資訊安全目標，擬定年度待辦事項、所需資源、負責人員、預計完成時間以及結果評估方式與評估結果，相關監督與量測程序，應遵循本公司「資訊安全監督與量測管理程序」IS-V2-15 實施。

5.2.1.4 資訊安全執行組應於管理審查會議中，針對資訊安全目標有效性量測結果，向資訊安全委員會召集人進行報告。

5.2.2 責任

5.2.2.1 本公司的管理階層建立及審查此政策。

5.2.2.2 資訊安全執行組透過標準和程序以實施此政策。

5.2.2.3 所有人員須依照相關安全管理程序以維護資訊安全政策。

5.2.2.4 所有人員有責任報告資訊安全事件和任何已鑑別出之弱點。

5.2.2.5 任何危及資訊安全之行為，將視情節輕重追究其民事、刑事及行政責任或依本公司之相關規定進行懲處。

5.2.2.6 資訊安全政策與目標應傳達至內部及外部人員，並得透過內部公告、會議、教育訓練、官網、電子郵件等方式傳達，政策改版時亦同。
a. 公告資訊安全政策與目標。
b. 針對無資訊系統帳號之直接人員，應透過紙本公告方式進行溝通與傳達，如有非本國籍之直接人員，亦應使用外籍移工可閱讀之語言進行公告。
c. 紙本公告內容應包含公告核章、公告日期、公告政策版本資訊。
d. 應針對外部關注者進行資訊安全政策與目標之溝通與傳達，包括：對本公司提供服務之供應商與業務合作夥伴。
e. 非特定之第三方則透過對外平台進行公告，如：公司全球資訊網或主動寄給供應商。

5.2.3 審查

5.2.3.1 本政策應至少每年審查乙次，以反映政府法令、技術及業務等最新發展現況，以確保本公司永續運作及資訊安全實務作業能力。

5.2.4 實施

5.2.4.1 資訊安全政策配合管理審查會議進行資訊安全手冊審核。

5.2.4.2 本公司各部門基於業務屬性差異，執行資訊安全管理作業並互相支援。

5.2.4.3 各單位執行資訊安全管理作業，如下列項目需進行變更，應依規劃之方式執行變更。
a. 資訊安全管理系統變更

b. 發生重大資安事故

c. 有新增、變更或移除重要資訊資產

d. 作業環境改變

5.2.4.4 如需進行變更，應考量下列事項：

a. 變更的目的與其潛在之影響

b. 管理系統的完整性

c. 資源的可用性

d. 職責與權限之分配或重新分配

5.2.4.5 本政策經「資訊安全管理委員會」進行會審後，由召集人核定後實施，修訂時亦同。

5.3 組織角色、責任及權限：

5.3.1 資訊安全委員會：為任務編組方式組成，由本公司數智驅動轉型處處經理擔任召集人與管理代表，如因職務調動應即刻指派遞補人員與辦理交接。

5.3.2 每年定期或視需要召開會議，審查資訊安全管理相關事宜。

5.3.3 視需要召開跨部門之資源協調會議，負責資安各標準制度之建置、實施與維持，資源調度等事項之協調及研議。

5.3.4 定期向主任委員報告資訊安全管理系統之績效。

委員會之組織依照「資訊安全組織程序」IS-V2-01 實施。

5.3.5 資訊安全流程與活動之權責單位

5.3.5.1 數智驅動轉型處（簡稱：數智處，英文名稱：DIC, Digital Intelligence Center）

a. 負責集團企業資訊最高決策

b. 綜理資訊安全政策推動及資源調度事務

5.3.5.2 情資安全部（簡稱：資安部，英文名稱：CSD, Cybersecurity Dept.）

a. 資安適用性聲明書版本及其排除控制項目

b. 資安驗證範圍其及人數

c. 資安驗證標章使用

d. 資安組織背景

e. 資安內部組織

f. 資安績效評估與改善/內部稽核/管理審查

g. ISMS 處境、規劃與運作

h. 人力資源安全

i. 遵循性與資安審查

j. 資安事故管理

k. 威脅情資

l. 網路安全管理(新樂廠/新仁廠)

m. Firewall, Anti-Virus, Endpoint Security, Cas, Log 等系統維護

5.3.5.2.1 情資安全部最高負責人

a. 資訊安全管理委員會當然成員

b. 訂立部門預算計劃、人力、年度目標
c. 資安管理系統維運
d. 行政簽核、考核等作業

5.3.5.3 智慧賦能部（簡稱：智能部，英文名稱：IED, Intelligent Empowerment Dept.）

a. MES 開發管理
b. MES 伺服器管理(新樂廠/新仁廠)
c. 機房管理(新樂廠/新仁廠)
d. 使用者端點管理(新樂廠/新仁廠)
e. VM 伺服器管理(新樂廠/新仁廠)
f. 基礎設施伺服器管理(新樂廠/新仁廠)
g. 網路管理(新樂廠/新仁廠)
h. Domain, Mail, Git, File, NAS, EIP, DTD, CIM, APS, WMS, AI, Lic 等系統維護

5.3.5.3.1 智慧賦能部最高負責人

a. 負責公司之 AI 人工智慧決策工廠
b. 資訊安全管理委員會緊急應變組組長
c. 訂立部門預算計劃、人力、年度目標
d. 資訊系統維運
e. 內部系統之 AI 化推動
f. 主導 AI 新專案技術路線圖
g. 業務發展成果衡量
h. OT 安全性評估
i. 行政簽核、考核等作業

5.3.5.4 數位整合部（簡稱：數整部，英文名稱：DID, Digital Integration Dept.）

a. ERP 開發管理
b. ERP 伺服器管理
c. 系統開發與維護
d. Application 存取控制
e. 供應商關係
f. 運作安全
g. Report, BPM, PLM, EDI, Web, RPA, SCM, CRM, GPM, DMP 等系統維護

5.3.5.4.1 數位整合部最高負責人

a. 負責資訊系統之數位發展與架構整合
b. 資訊安全管理委員會當然成員
c. 訂立部門預算計劃、人力、年度目標
d. 資訊應用系統維運
e. 內部系統之數位化與資料整合推動
f. 主導 IT 新專案技術路線圖
g. 業務發展成果衡量

h. IT 安全性評估

i. 行政簽核、考核等作業

5.3.5.5 其他部門

a. 產品設計一部：新產品可行性評估與電子電路開發設計

b. 產品設計二部：新產品可行性評估與結構與美工設計

c. 資料課：維護 BOM List、製造規格書、工程變更、試作等資料

d. 資材部：原物料採購與物料流程追蹤管理

r. 工程部：試作檢視與製程需求治具評估

f. 製造部：製造環境的資訊設備安全防護

g. SMT 部：製造環境的資訊設備安全防護

h 成型部：製造環境的資訊設備安全防護

i. 專案管理部：新產品可行性評估、策略規劃

j. 技術部：技術基礎研究、應用分析、概念驗證、應用規劃

k. 業務部：客戶資安要求調查，以滿足法規之要求

m. 市場行銷部：制定產品路線圖與技術路線圖

n. 管理部：廠務設施、監視活動、門禁系統等管理

o. 人資部：人資安全、保密約定、教育訓練等管理

p. 品質保證部：內部稽核

q. 永續發展部：公司官方網站管理

6.0 規劃：

6.1 因應風險及機會之行動

6.1.1 資訊資產價值之數值若為 7（含 7）以上，必須進行威脅弱點評估。

6.1.2 資訊資產之機密性、可用性及完整性之數值，若其中一項數值為 4 者，必須進行威脅弱點評估。

6.2 資訊安全目標與期達成之規劃

6.2.1 資訊安全目標

6.2.1.1 依據本手冊 5.2.1.2 擬定之資訊安全目標。

6.3 變更之規劃

6.3.1 風險與機會重新評估：有新增、變更或移除資訊資產，且該資訊資產價值超過 7(含 7)以上。

7.0 支援：

7.1 資源

7.1.1 為建立本公司資訊安全管理制度（以下簡稱 ISMS）風險評鑑與管理規範，提供本公司資訊流程之權責單位、保管單位，以及使用單位，共同遵行之風險評鑑標準，有效執行風險控管，預防資訊安全事件之威脅。

7.2 能力

7.2.1 職能分析：為確保本公司執行資訊安全各項作業的人員，皆能有充足之能力來確保資訊安全的運作績效，故資訊安全執行組應分析各項職務所需之職能，並將分析結果填入「人員職掌清冊」IS-V2-05-01。

7.2.2 職能評估：資訊安全執行組應於年度管理審查會議時，提報現有人員職能評估成果，並針對職能落差部份，擬定改善計畫，並取得管理階層之核准。
依「人員資訊安全與教育訓練程序」IS-V2-05 實施。

7.3 認知

7.3.1 資訊安全管理制度人員範圍：本公司之所有單位人員與委外廠商。
需遵守「人員資訊安全守則」IS-V2-05-02。

7.3.2 為確保營運持續運作，並降低關鍵性業務流程受重大故障或災害之影響。

7.3.3 違反資安政策之懲處依據本手冊 5.2.2.5 之相關規定進行。

7.4 溝通或傳達

7.4.1 為確保與內、外部關注者具備有效的溝通與傳達管道，應於年度管理審查時，決定溝通與傳達之事項，包括：

7.4.1.1 溝通或傳達事項

7.4.1.2 溝通或傳達時間

7.4.1.3 溝通或傳達對象

7.4.1.4 溝通或傳達方式

7.4.2 傳達方式依據本手冊 5.2.2.6 之相關規定進行。

7.5 文件化資訊

7.5.1 表單或紀錄至少需保留三年，且考慮法律上資料保存期限之要求。

7.5.2 資訊資產依其性質不同，分為 7 類：人員、文件、軟體、通訊、硬體、資料、環境。

7.5.3 機密性評估標準

7.5.3.1 一般：此資訊資產無特殊之機密性要求

7.5.3.2 限閱：此資訊資產含密資訊，但無特殊之機密性要求，且僅供本公司內部人員使用

7.5.3.3 密：此資訊資產僅供本公司內部相關業務承辦人員存取

7.5.3.4 機密：此資訊資產所包含資訊為本公司或法律所規範的機密資訊

資安相關文件依「資訊安全文件管理辦法」IS-V3-07 辦理。

8.0 運作：

8.1 運作之規劃及控制

8.1.1 以適用性聲明(Statement of Applicability, SOA)明列本公司資訊安全管理制度之管理架構的目標、控制及對策。

8.2 資訊安全風險評鑑

8.2.1 完整性評估標準

8.2.1.1 微或無：不會造成任何影響或其影響是可忽略的

8.2.1.2 低：對本公司業務之營運造成輕微影響

8.2.1.3 中：對本公司業務之營運造成中度影響，但不至於造成業務停頓

8.2.1.4 高：對本公司業務之營運造成高度影響且致使業務停頓

8.2.2 可用性評估標準

8.2.2.1 微或無：可容忍該資訊資產失效 40 工作小時以上

8.2.2.2 低：可容忍該資訊資產失效超過 16 工作小時，40（含）工作小時以下

8.2.2.3 中：可容忍該資訊資產失效超過 8 工作小時，16（含）工作小時以下

8.2.2.4 高：僅可容忍該資訊資產失效 8（含）工作小時需被修復

8.2.3 事件發生機率/等級對應表

8.2.2.1 微或無：無發生可能或不適用之情形，平均三年發生之次數約 1 次或不發生，或屬於天災無法預估其發生可能性

8.2.2.2 低：很少發生，平均一年發生之次數約 1 次，或三年 1 次以上 3 次以下

8.2.2.3 中：偶爾發生，平均一季發生之次數約 1 次，或一年 1 次以上 4 次以下

8.2.2.4 高：經常發生，平均一個月發生次數 1 次以上，或一季發生 2 次

8.2.4 衝擊評估標準/等級對應表

8.2.4.1 微或無：可以立即完成復原

8.2.4.2 低：修復或進行復原的措施可以在很短時間(一天)內完成

8.2.4.3 中：復原可能要超過一天到三天才能完成

8.2.4.4 高：復原無法於三天到一週內完成

8.3 資訊安全風險處理

8.3.1 可接受風險值的決定，需經風險擁有者核准。

8.3.2 選擇控制措施：產出「風險改善與機會實作計畫表」IS-V2-04-01，說明風險控管措施之執行辦法，並列入追蹤管理程序。

追蹤依「資訊安全風險評鑑與管理程序」IS-V2-04 實施。

8.3.3 風險改善「資訊安全風險評鑑與管理程序」IS-V2-04 狀況的後續追蹤：對風險評鑑後所提出之風險改善計畫應彙整控管，持續追蹤至完成改善為止。

8.3.4 產出「適用性聲明」IS-V2-04-02。

9.0 績效評估：

9.1 監督、量測、分析及評估

9.1.1 針對本公司評估資訊安全績效及資訊安全管理系統之有效性，以確保資訊安全目標的符合性與適切性。

9.2 內部稽核

9.2.1 建立本公司獨立稽核之規範，以判斷各項作業的控制目標、措施、流程及程序是否符合法規及本公司之資訊安全要求。

依「資訊安全稽核作業程序」IS-V2-13 實施，稽核對照表如附件。

9.3 管理審查

9.3.1 資訊安全委員會每年應召開一次「管理審查會議」，必要時得召開臨時會議。

9.3.2 管理審查會議審查內容建議包含如下：

9.3.2.1 先前管理審查之行動狀態。

9.3.2.2 與資訊安全管理系統有關之內部及外部議題之變更。

9.3.2.3 與資訊安全管理系統相關關注方之需要及期望的變更。

9.3.2.4 資訊安全績效之回饋，包含下列趨勢：

a. 稽核結果

b. 不符合項目及矯正措施

c. 資訊安全目標符合度

d. 監視與量測結果

9.3.2.5. 關注各方之回饋

9.3.2.6. 風險評鑑結果及風險處理計畫之狀態

9.3.2.7. 持續改善之機會

9.3.3 管理審查會議之結論建議應包括與持續改善機會有關之決策，以及任何對資訊安全管理系統變更之需要。

10.0 改善：

10.1 持續改善

10.1.1 針對本公司資訊安全管理制度（ISMS）運作過程中發生之缺失及潛在之風險，採取相關的矯正及持續改善措施，以防止類似事件發生，進而達成持續改善之目標。
依「資訊安全矯正及持續改善管理程序」IS-V2-14 實施。

10.2 不符合事項及矯正措施

10.2.1 缺失：不符合資訊安全管理制度（ISMS）實施及操作事項者。依影響程度分為：

10.2.1.1 主要缺失：未執行資訊安全管理制度（ISMS）之要求，或多個次要缺失集中於同一控制措施者。

10.2.1.2 次要缺失：未能完全遵循資訊安全管理制度（ISMS）之要求，但為單一事件者。

10.2.1.3 觀察事項：發現可能對資訊安全管理制度（ISMS）造成影響的事實及事件，但未有足夠證據顯示會影響資訊安全政策及目標的達成，卻因未來可能成為缺失而需要再覆核。

10.2.1.4 建議事項：發現可能對資訊安全管理制度（ISMS）造成影響的潛在問題，可提出建議之改善措施，以持續改善未來發生之可能性。

10.2.2 矯正處理單

10.2.2.1 內部及外部稽核發現缺失時，缺失權責單位需提出矯正措施，並填寫於「資訊安全矯正處理單」IS-V2-14-01。

10.2.2.2 發生資訊安全事件（含重大異常事件）或自行發現缺失時，應執行矯正或持續改善措施，並填寫於「資訊安全矯正處理單」IS-V2-14-01。

10.2.2.3 矯正與持續改善措施之執行狀況，應由缺失權責單位依據「資訊安全矯正處理單」IS-V2-14-01 確實執行。

附件：ISO27001 資訊安全管理標準要求與內部適用文件稽核對照表

項次	標　準　要　求	適用文件
	本文 4～10 章	
4	**組織全景**	
4.1	瞭解組織及其全景	IS-V2-02　組織全景分析程序 IS-V2-02-01　全景分析作業表
4.2	瞭解關注方之需要及期望	IS-V2-02　組織全景分析程序 IS-V2-02-01　全景分析作業表
4.3	決定資訊安全管理系統之範圍	IS-V2-02　組織全景分析程序 IS-V2-02-01　全景分析作業表 IS-V2-04-02　適用性聲明
4.4	資訊安全管理系統	IS-V2-02　組織全景分析程序 IS-V2-02-01　全景分析作業表
5	**領導作為**	
5.1	領導及承諾	IS-V2-01　資訊安全組織程序
5.2	政策	IS-V1-01　資訊安全政策手冊
5.3	組織角色、責任及權限	IS-V2-01　資訊安全組織程序
6	**規劃**	
6.1	因應風險及機會之行動	
6.1.1	一般要求	IS-V2-04　資訊安全風險評鑑與管理程序
6.1.2	資訊安全風險評鑑	IS-V2-04　資訊安全風險評鑑與管理程序
6.1.3	資訊安全風險處理	IS-V2-04　資訊安全風險評鑑與管理程序 IS-V2-04-01　風險改善與機會實作計畫表 IS-V2-04-02　適用性聲明
6.2	資訊安全目標及其達成之規劃	IS-V2-04　資訊安全風險評鑑與管理程序
6.3	變更之規劃	IS-V2-04　資訊安全風險評鑑與管理程序 IS-V1-01　資訊安全政策手冊
7	**支援**	
7.1	資源	IS-V1-01　資訊安全政策手冊 IS-V2-01　資訊安全組織程序 IS-V2-01-01　資訊安全組織成員表
7.2	能力	IS-V2-05　人員資訊安全與教育訓練程序 IS-V2-05-01　人員職掌清冊
7.3	認知	IS-V1-01　資訊安全政策手冊 IS-V2-05　人員資訊安全與教育訓練程序 IS-V2-05-02　人員資訊安全守則
7.4	溝通或傳達	IS-V2-05　人員資訊安全與教育訓練程序

7.5	文件化資訊	
7.5.1	一般要求	IS-V3-07　資訊安全文件管理辦法
7.5.2	制訂及更新	IS-V3-07　資訊安全文件管理辦法 IS-V3-07-02 文件修訂建議表 SP1-Q2-01-02 文件變更紀錄表
7.5.3	文件化資訊之控制	IS-V3-07　資訊安全文件管理辦法 IS-V3-07-03 資訊安全管理文件列表
8	**運作**	
8.1	運作之規劃及控制	所有二~三階 ISMS 文件
8.2	資訊安全風險評鑑	IS-V2-04　資訊安全風險評鑑與管理程序 IS-V2-04-03 威脅弱點評估表
8.3	資訊安全風險處理	IS-V2-04　資訊安全風險評鑑與管理程序 IS-V2-04-01 風險改善與機會實作計畫表 IS-V2-04-04 風險與機會評鑑報告
9	**績效評估**	
9.1	監督、量測、分析及評估	IS-V2-15　資訊安全監督與量測管理程序 IS-V2-15-01 ISMS 有效性量測表 IS-V2-15-02 資訊安全目標有效性量測表
9.2	內部稽核	
9.2.1	一般要求	IS-V2-13　資訊安全稽核作業程序
9.2.2	內部稽核計畫	IS-V2-13　資訊安全稽核作業程序 IS-V2-13-01 資訊安全管理制度內部稽核計畫 IS-V2-13-02 資訊安全管理制度內部稽核表 IS-V2-13-03 資訊安全內部稽核報告
9.3	管理審查	
9.3.1	一般要求	IS-V2-01　資訊安全組織程序
9.3.2	管理審查輸入	IS-V2-01　資訊安全組織程序
9.3.3	管理審查結果	IS-V2-01　資訊安全組織程序 EP-A2-12-01 會議記錄表
10	**改善**	
10.1	持續改善	IS-V2-14　資訊安全矯正及持續改善管理程序
10.2	不符合項目及矯正措施	IS-V2-14　資訊安全矯正及持續改善管理程序 IS-V2-14-01 資訊安全矯正處理單

附件：TISAX ISA 6.0.3 Statement of Applicability 與內部適用文件稽核對照表

項次	標　準　要　求	適用文件
	Iinformation Security	
1.1.1	To what extent are information security policies available? 資訊安全政策涵蓋到什麼程度？	IS-V1-01 資訊安全政策手冊
1.2.1	To what extent is information security managed within the organization? 資訊安全在組織內管理涵蓋到什麼程度？	IS-V2-02 組織全景分析程序
1.2.2	To what extent are information security responsibilities organized? 資訊安全責任編制涵蓋到什麼程度？	IS-V2-01 資訊安全組織程序
1.2.3	To what extent are information security requirements considered in projects? 在各項專案考慮資訊安全需求到什麼程度？	IS-V2-04 資訊安全風險評鑑與管理程序 IS-V2-16 機密車規專案管理程序
1.2.4	To what extent are the responsibilities between external IT service providers and the own organization defined? 外部 IT 服務提供者與組織之間的責任要定義到什麼程度？	IS-V2-10 委外管理程序
1.3.1	To what extent are information assets identified and recorded? 資訊資產要識別並記錄到什麼程度？	IS-V2-03 資訊資產管理程序 IS-V3-01 資訊資產管理辦法
1.3.2	To what extent are information assets classified and managed in terms of their protection needs? 資訊資產依據保護需求，要分類及管理到什麼程度？	IS-V2-03 資訊資產管理程序 IS-V3-01 資訊資產管理辦法
1.3.3	To what extent is it ensured that only evaluated and approved external IT services are used for processing the organization's information assets? 只使用經過評估和核准的外部 IT 服務來處理組織的資訊資產，要確認到什麼程度？	IS-V2-03 資訊資產管理程序 IS-V3-01 資訊資產管理辦法 IS-V2-10 委外管理程序
1.3.4	To what extent is it ensured that only evaluated and approved software is used for processing the organization's information assets? 確保僅使用經過評估和核准的軟體來處理組織的資訊資產，需執行到什麼程度？	IS-V2-03 資訊資產管理程序 IS-V3-01 資訊資產管理辦法
1.4.1	To what extent are information security risks managed? 資訊安全風險要管理到什麼程度？	IS-V2-04 資訊安全風險評鑑與管理程序

1.5.1	To what extent is compliance with information security ensured in procedures and processes? 在程序和流程中遵循資訊安全，要確認到什麼程度？	IS-V2-13 資訊安全稽核作業程序 IS-V2-14 資訊安全矯正及持續改善管理程序
1.5.2	To what extent is the ISMS reviewed by an independent authority? 由獨立單位審查 ISMS，要實施到什麼程度？	IS-V2-13 資訊安全稽核作業程序 IS-V2-14 資訊安全矯正及持續改善管理程序
1.6.1	To what extent are information security relevant events or observations reported? 資訊安全事件要通報到什麼程度？	IS-V2-11 資訊安全事件管理程序
1.6.2	To what extent are reported security events managed? 報告的資訊安全事件要管理到什麼程度？	IS-V2-11 資訊安全事件管理程序 RBA-H2-08 緊急應變與準備管理程序
1.6.3	To what extent is the organization prepared to handle crisis situations? 在處理危機情況的資訊安全事件要準備到什麼程度？	IS-V2-11 資訊安全事件管理程序 RBA-H2-08 緊急應變與準備管理程序
2.1.1	To what extent is the qualification of employees for sensitive work fields ensured? 員工的敏感工作領域適切性要確認到什麼程度？	IS-V2-05 人員資訊安全與教育訓練程序 SP2-U3-02 招募甄選與任用管理辦法
2.1.2	To what extent is all staff contractually bound to comply with information security policies? 所有員工都受合約約束須遵守資訊安全政策，要實施到什麼程度？	IS-V2-05 人員資訊安全與教育訓練程序 SP2-U3-02-08 服務約定書及火誠信連結暨智慧財產權約定書
2.1.3	To what extent is staff made aware of and trained with respect to the risks arising from the handling of information? 讓員工認知處理資訊所產生的風險並對其進行訓練，要實施到什麼程度？	IS-V2-05 人員資訊安全與教育訓練程序
2.1.4	To what extent is mobile work regulated? 遠距辦公要監管到什麼程度？	IS-V3-02 網路及系統安全管理辦法
3.1.1	To what extent are security zones managed to protect information assets? 管理安全區域以保護資訊資產，要實施到什麼程度？	IS-V2-06 實體安全管理程序 CT-A2-06 門禁控制管理程序
3.1.2	Superseded by 1.6.3, 5.2.8 and 5.2.9 已被 1.6.3、5.2.8 和 5.2.9 取代	NA
3.1.3	To what extent is the handling of supporting assets managed? 支援性資產的處置，要管理到什麼程度？	IS-V2-03 資訊資產管理程序 IS-V3-01 資訊資產管理辦法
3.1.4	To what extent is the handling of mobile IT devices and mobile data storage devices managed?	IS-V2-07 通訊與作業管理程序

	行動 IT 裝置與行動資料儲存裝置的處置，要管理到什麼程度？	
4.1.1	To what extent is the use of identification means managed? 身份識別方式的使用，要管理到什麼程度？	IS-V2-08 存取控制管理程序 CT-A2-06 門禁控制管理程序
4.1.2	To what extent is the user access to IT services and IT systems secured? 使用者存取網路服務，IT 系統與 IT 應用程式，要保全到什麼程度？	IS-V2-08 存取控制管理程序 IS-V2-07 通訊與作業管理程序 IS-V3-02 網路及系統安全管理辦法 IS-V3-04 帳號及通行密碼管理辦法
4.1.3	To what extent are user accounts and login information securely managed and applied? 使用者帳號與登入資訊，要安全管理與應用到什麼程度？	IS-V2-08 存取控制管理程序 IS-V3-04 帳號及通行密碼管理辦法
4.2.1	To what extent are access rights assigned and managed? 存取權限指派與管理，要實施到什麼程度？	IS-V2-08 存取控制管理程序 IS-V3-04 帳號及通行密碼管理辦法
5.1.1	To what extent is the use of cryptographic procedures managed? 密碼程序的使用，要管理到什麼程度？	IS-V2-07 通訊與作業管理程序 IS-V3-02 網路及系統安全管理辦法 IS-V2-09 系統開發與維護作業程序
5.1.2	To what extent is information protected during transfer? 資訊在傳輸過程的保護，要實施到什麼程度？	IS-V2-07 通訊與作業管理程序 IS-V3-02 網路及系統安全管理辦法
5.2.1	To what extent are changes managed? 變更管理要實施到什麼程度？	IS-V2-01 資訊安全組織程序 IS-V2-07 通訊與作業管理程序 IS-V2-09 系統開發與維護作業程序
5.2.2	To what extent are development and testing environments separated from operational environments? 開發環境與測試環境要與運作環境區隔到什麼程度？	IS-V2-07 通訊與作業管理程序 IS-V2-09 系統開發與維護作業程序
5.2.3	To what extent are IT systems protected against malware? IT 系統需防範惡意軟體到什麼程度？	IS-V2-07 通訊與作業管理程序 IS-V3-03 惡意軟體防護管理辦法
5.2.4	To what extent are event logs recorded and analysed? 識別並解決脆弱性要實施到什麼程度？	IS-V2-07 通訊與作業管理程序
5.2.5	To what extent are vulnerabilities identified and addressed? 漏洞在多大程度上被識別和解決？	IS-V2-07 通訊與作業管理程序
5.2.6	To what extent are IT systems and services technically checked (system and service audit)? IT 系統技術性檢查（系統稽核）要實施到什麼程度？	IS-V2-07 通訊與作業管理程序

5.2.7	To what extent is the network of the organization managed? 組織的網路要管理到什麼程度？	IS-V2-07 通訊與作業管理程序 IS-V3-02 網路及系統安全管理辦法
5.2.8	To what extent is continuity planning for IT services in place? IT 服務的營運持續性規劃要實施到什麼程度？	IS-V2-12 資訊安全營運持續運作管理程序 RBA-H2-08 緊急應變與準備管理程序
5.2.9	To what extent is the backup and recovery of data and IT services ensured? 資料和 IT 服務的備份和恢復要保證到什麼程度？	IS-V2-12 資訊安全營運持續運作管理程序 IS-V3-05 資訊備份管理辦法
5.3.1	To what extent is information security considered in new or further developed IT systems? 在新的或進一步的 IT 系統開發時，要考慮資訊安全到什麼程度？	IS-V2-09 系統開發與維護作業程序 IS-V3-06 系統開發與維護作業管理辦法
5.3.2	To what extent are requirements for network services defined? 網路服務的要求要定義到什麼程度？	IS-V2-07 通訊與作業管理程序 IS-V3-02 網路及系統安全管理辦法
5.3.3	To what extent is the return and secure removal of information assets from external IT services regulated? 從受監管的外部 IT 服務返還，並需要安全移除的資訊資產，要實施到什麼程度？	IS-V2-10 委外管理程序
5.3.4	To what extent is information protected in shared external IT services? 在共享的外部 IT 服務中的資訊，要保護到什麼程度？	IS-V2-10 委外管理程序
6.1.1	To what extent is information security ensured among contractors and cooperation partners? 供應商和合作夥伴之間的資訊安全，要確認到什麼程度？	IS-V2-10 委外管理程序
6.1.2	To what extent is non-disclosure regarding the exchange of information contractually agreed? 合約允許的資訊交換，保密協定要實施到什麼程度？	IS-V2-10 委外管理程序
7.1.1	To what extent is compliance with regulatory and contractual provisions ensured? 遵循法規和合約條款要確認到什麼程度？	IS-V3-07 資訊安全文件管理辦法 IS-V2-05 人員資訊安全與教育訓練程序
7.1.2	To what extent is the protection of personally identifiable data considered when implementing information security? 在實施資訊安全時考慮到的個人資料保護，要實施到什麼程度？	RBA-U2-10 個人資料保護管理程序